

CVEs más relevantes de la semana

Del 20/06/2026 al 27/06/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-12773

Descripción: A weakness has been identified in BerriAI litellm up to 1.59.8. Affected is the function UserAPIKeyAuth of the file litellm/proxy/_experimental/mcp_server/auth/user_api_key_auth_mcp.py of the component MCP Proxy. Executing a manipulation can lead to improper authentication. The attack may be launched remotely. The exploit has been made available to the public and could be used for attacks. The ...

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-06-21



CVE-2026-56367

Descripción: ImageMagick before 7.1.2-15 and 6.9.x before 6.9.13-40 contains an integer overflow in the PSB (PSD v2) RLE decoding path (ReadPSDChannelRLE in coders/psd.c) that causes a heap out-of-bounds read on 32-bit builds. Processing a crafted PSB file can lead to information disclosure or a crash.

CVSS: 3.7 (LOW)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-06-21



CVE-2026-8646

Descripción: IBM WebSphere Application Server 9.0 and 8.5 and IBM WebSphere Application Server - Liberty 17.0.0.3 through 26.0.0.6 are vulnerable to HTTP request smuggling. A remote attacker could smuggle a specially crafted request to the application server thereby allowing the attacker to bypass security controls, spoof identity, escalate privilege, and expose sensitive information.

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-444

Tecnología: No especificado

Publicado el: 2026-06-22



CVE-2026-9006

Descripción: IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to server-side request forgery (SSRF) with the Ajax Proxy configured. This may allow an attacker to send unauthorized requests from the system, resulting in a security bypass or information disclosure.

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-06-22



CVE-2026-9072

Descripción: IBM WebSphere Application Server and IBM WebSphere Application Server Liberty - when using Intelligent Management with the WebSphere WebServer Plug-in component - are vulnerable to remote code execution and denial of service. This vulnerability can be exploited when an attacker impersonates backend servers and sends crafted responses to the plug-in.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-06-22



CVE-2026-49468

Descripción: LiteLLM is a proxy server (AI Gateway) to call LLM APIs in OpenAI (or native) format. Prior to 1.84.0, This vulnerability is fixed in 1.84.0.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-06-22



CVE-2026-48509

Descripción: MessagePack for C# is a MessagePack serializer for C#. Prior to 2.5.301 and 3.1.7, the parameterless MessagePackInputFormatter() constructor uses default serializer options, which resolve to MessagePackSerializerOptions.Standard with MessagePackSecurity.TrustedData. The formatter is designed for ASP.NET Core MVC request bodies, which commonly cross an HTTP trust boundary. This insecure default ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-1188

Tecnología: No especificado

Publicado el: 2026-06-22



CVE-2026-56348

Descripción: n8n before 2.20.0 contains a credential exfiltration vulnerability in the POST /rest/dynamic-node-parameters/options endpoint that allows authenticated users to bypass Allowed HTTP Request Domains restrictions. Attackers with credential access can cause the n8n server to issue HTTP requests with credentials to unauthorized hosts, exfiltrating sensitive authentication data.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-06-22



CVE-2026-54309

Descripción: n8n is an open source workflow automation platform. Prior to 2.25.7 and 2.26.2, when @n8n/mcp-browser is run in HTTP transport mode, the MCP endpoint accepts session initialization and tool invocation requests without any authentication. Any network-reachable client, or any website visited by the user, can establish an MCP session and invoke browser-control tools. Where the n8n AI Browser Bridg...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-54310

Descripción: n8n is an open source workflow automation platform. Prior to 2.25.7 and 2.26.2, an authenticated user with permission to create or modify workflows could supply a crafted parameters to the TimescaleDB and/or legacy Postgres v1 node's allowing arbitrary SQL to be injected and executed against the connected database within the privileges of the configured database account. This vulnerability is f...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-44789

Descripción: n8n is an open source workflow automation platform. Prior to 1.123.43, 2.22.1, and 2.20.7, an authenticated user with permission to create or modify workflows could achieve global prototype pollution via an unvalidated pagination parameter in the HTTP Request node. Combined with other techniques this could lead to RCE on the instance. This vulnerability is fixed in 1.123.43, 2.22.1, and 2.20.7.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-1321

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-44791

Descripción: n8n is an open source workflow automation platform. Prior to 1.123.43, 2.22.1, and 2.20.7, an authenticated user with permission to create or modify workflows could bypass the patch for CVE-2026-42232 in the XML node. When combined with other nodes, this could lead to RCE on the n8n host. This vulnerability is fixed in 1.123.43, 2.22.1, and 2.20.7.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-1321

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-44792

Descripción: n8n is an open source workflow automation platform. Prior to 1.123.43, 2.22.1, and 2.20.7, an attacker with write access to the git repository connected to an n8n Source Control configuration could commit a malicious Data Table JSON file containing a crafted column name. When an administrator performed a Source Control Pull, n8n imported the file and could lead to SQL injection on the internal ...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-50023

Descripción: yt-dlp is a command-line audio/video downloader. Prior to 2026.06.09, a vulnerability exists in yt-dlp that allows a remote attacker to write arbitrary OS-shortcut files (such as .desktop, .url, .webloc) to the user's filesystem, bypassing the remediation for CVE-2024-38519. The allowlist explicitly included the unsafe extensions .desktop, .url, and .webloc so that the functionality of the --wr...

CVSS: 8.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-641

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-50574

Descripción: yt-dlp is a command-line audio/video downloader. Prior to 2026.06.09, if aria2c is used as an external downloader for a fragmented manifest format (such as an HLS/DASH stream), yt-dlp passes insufficiently sanitized input to aria2c that allows an attacker to perform an arbitrary file write. On Windows platforms, this can lead to immediate arbitrary code execution. On non-Windows platforms, this...

CVSS: 8.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-54305

Descripción: n8n is an open source workflow automation platform. Prior to 1.123.55, 2.25.7, and 2.26.2, three EE endpoints used by the Dynamic Credentials feature accepted any authenticated n8n session without performing per-resource ownership or scope checks on the target workflow or credential. An authenticated user with no project membership or credential sharing relationship could enumerate credential i...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-200

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-54307

Descripción: n8n is an open source workflow automation platform. Prior to 1.123.55, 2.25.7, and 2.26.2, a member-level user with editor access to a shared workflow could reference credentials they do not own via specific public API endpoints. Credential ownership checks were only enforced partially leading to cross-user credential access. This issue affects instances where workflow sharing is enabled and at...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-44726

Descripción: Deno is a JavaScript, TypeScript, and WebAssembly runtime. From 2.0.0 until 2.7.8, a flaw in Deno's Node.js tls compatibility layer could cause a TLS client to transmit application data in plaintext after a connection retry. When `autoSelectFamily` was enabled and the first address-family attempt failed, the socket reinitialization path reused a stale TLS upgrade hook that was bound to the origi...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-319

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-48020

Descripción: Traefik is an HTTP reverse proxy and load balancer. Prior to 2.11.48, 3.6.19, and 3.7.3, there is a high severity vulnerability in Traefik's StripPrefix middleware that allows an unauthenticated attacker to bypass route-level authentication and authorization. When a public router matches on a PathPrefix rule and applies the StripPrefix middleware, a request path containing .. or its percent-enc...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-48491

Descripción: Traefik is an HTTP reverse proxy and load balancer. From 3.7.0 until 3.7.3, there is a high severity vulnerability in Traefik's domain-fronting protection (SNICheck) that allows an unauthenticated client to bypass mutual TLS enforced through wildcard router TLSOptions. When a router uses a wildcard host rule such as Host(*.example.com) with stricter TLS options (for example RequireAndVerifyClie...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-53622

Descripción: Traefik is an HTTP reverse proxy and load balancer. Prior to 3.7.3, there is a critical vulnerability in Traefik's HTTP/3 (QUIC) TLS configuration selection that allows unauthenticated clients to bypass router-specific mTLS enforcement. When HTTP/3 is enabled on an entrypoint, the TLS handshake selects the applicable TLS configuration through an exact, case-sensitive lookup on the SNI value, wh...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-06-23



CVE-2026-12417

Descripción: The SignUp & SignIn plugin for WordPress is vulnerable to Authentication Bypass via Weak Password Reset Validation leading to Account Takeover in versions up to, and including, 1.0.0. This is due to the ``pravel_change_password()`` AJAX handler — registered via ``wp_ajax_nopriv_prael_change_password`` and therefore accessible to unauthenticated users — performing no nonce verification, no capabili...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-640

Tecnología: No especificado

Publicado el: 2026-06-24



CVE-2026-56351

Descripción: n8n before version 2.4.0 contains a sql injection vulnerability in MySQL, PostgreSQL, and Microsoft SQL nodes that allows authenticated users to inject arbitrary SQL through unescaped identifier values in node configuration parameters. Attackers with workflow creation permissions can supply specially crafted table or column names to execute unauthorized database commands and compromise data integrity.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-06-24



CVE-2026-54906

Descripción: concurrent-ruby is a modern concurrency tools for Ruby. Prior to 1.3.7, Concurrent::ReadWriteLock#release_write_lock does not verify that the calling thread acquired the write lock. Any thread with access to the lock object can release an active write lock held by another thread. A second writer can then enter its critical section while the first writer is still running.

Concurrent::ReadWriteLo...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-414

Tecnología: No especificado

Publicado el: 2026-06-24



CVE-2026-55455

Descripción: Appsmith is a platform to build admin panels, internal tools, and dashboards. Prior to 2.1, the outbound HTTP host filter applied by WebClientUtils (used by the REST API and GraphQL datasource plugins) validates hosts against an exact-match string denylist. The comprehensive address-class check (loopback, any-local, link-local, fc00::/7) exists only on a separate code path used by SMTP, not by ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-06-24



CVE-2026-39948

Descripción: Cacti is an open source performance and fault management framework. In versions 1.2.30 and prior, the rfilter request parameter is retrieved via the raw accessor grv() (rather than gfrv() with FILTER_VALIDATE_IS_REGEX validation) and concatenated directly into RLIKE SQL clauses in lib/html_graph.php and lib/html_tree.php, which are reachable pre-authentication through graph_view.php on installa...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-06-24



CVE-2026-40079

Descripción: Cacti is an open source performance and fault management framework. Versions 1.2.30 and prior are vulnerable to Command Injection due to lack of sanitization in the `escape_command()` function. The `escape_command()` function at `lib/rrd.php` is a no-op: it returns `$command` unchanged. The command line built by `rrdtool_function_graph()` is passed through this function and then to `shell_exec($full_comma...`

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-25



CVE-2026-56123

Descripción: socat versions 1.8.0.0 through 1.8.1.1 contain a heap-based buffer overflow vulnerability that allows a malicious SOCKS5 proxy server to overwrite adjacent heap memory by exploiting a sign-extension flaw in the DOMAINNAME reply parser. During connection setup, the domain name length byte is read through a signed char field causing a negative bytes_to_read value that is implicitly converted to s...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-06-25



CVE-2026-6094

Descripción: Heap buffer overread in wc_PKCS7_DecodeEnvelopedData when parsing crafted PKCS7 EnvelopedData. This could theoretically be triggered by attacker-supplied data delivered via S/MIME or CMS.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-06-25



CVE-2026-50548

Descripción: Cursor is a code editor built for programming with AI. Prior to 3.0, Cursor runs agent terminal commands in a sandbox by default, and the sandbox grants write access to the command's working directory. A flaw was identified in how the agent could modify the `working_directory` parameter, which could cause the sandbox to include writable paths outside the intended workspace. A malicious agent coul...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-06-25



CVE-2026-50549

Descripción: Cursor is a code editor built for programming with AI. Prior to 3.0, Cursor runs agent terminal commands in a sandbox by default. Before a Write, the agent canonicalizes the target path to confirm it stays inside the workspace, but when canonicalization fails it falls back to the original path and writes without approval. A malicious agent can create an in-workspace symlink that points outside ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-59

Tecnología: No especificado

Publicado el: 2026-06-25



CVE-2026-56786

Descripción: RTKLIB through 2.4.3 contains an out-of-bounds write vulnerability in decode_type1033 function that fails to clamp length counters to destination buffer size, allowing up to 191-byte overflow into fixed 64-byte descriptor fields. An attacker controlling an NTRIP or serial RTCM3 correction stream can craft a valid CRC-bearing type-1033 message to corrupt adjacent rtcm_t object members, potential...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-06-25



CVE-2026-7531

Descripción: Use-after-free in PQC hybrid key-share handling. This is an incomplete-fix follow-up to CVE-2026-5460 (released in 5.9.1): a malicious TLS 1.3 server sending a truncated PQC hybrid KeyShare can still trigger the error cleanup path to operate on freed memory.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-06-25



CVE-2025-71336

Descripción: Flowise before 3.0.6 (affected versions 2.2.7-patch.1 and earlier) contains an unsandboxed remote code execution vulnerability in the Custom MCP feature, which is designed to execute OS commands such as launching local MCP servers. Because Flowise's authentication and authorization model is minimal and lacks role-based access control, and the default installation runs without authentication unl...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-25



CVE-2026-48930

Descripción: A flaw in Node.js TLS hostname handling can cause Embedded-nul hostnames can lead to silent authority rebinding due to c-string truncation in resolver bindings. This vulnerability affects all supported release lines: ****Node.js 22****, ****Node.js 24****, and ****Node.js 26****.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-06-26



CVE-2026-54636

Descripción: Dokku is a docker-powered PaaS. Prior to 0.38.7, the cron plugin utilizes commands in the app.json file to manage system cron running as the Dokku user. An app.json cron command utilizing special shell characters - including, but not limited to, > or ; - can break out of the Docker container and execute commands on the host as the Dokku user. This vulnerability is fixed in 0.38.7.

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-26



CVE-2026-12415

Descripción: The Invoice Generator plugin for WordPress is vulnerable to privilege escalation due to a missing capability check on the `pravel_invoice_edit_account()` AJAX action in versions up to, and including, 1.0.0. The handler is exposed via `wp_ajax_nopriv_pravel_invoice_edit_account`, accepts an attacker-controlled `user_id` and `user_email` from POST data, and calls `wp_update_user()` without verifying authen...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-06-27



Resumen del Reporte

CVEs analizados: 37

Promedio CVSS: 9.06

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

